

Path traversal in PackageIndex.download leads to Arbitrary File Write. #4946

✓ Closed

jaraco opened on Apr 15, 2025 · edited by jaraco

Edits ▾

Member



Vulnerable Code

```
def _download_url(self, url, tmpdir):
    # Determine download filename
    #
    name, _fragment = egg_info_for_url(url)
    if name:
        while '..' in name:
            name = name.replace('..', '.').replace('\\', '_')
    else:
        name = "__downloaded__" # default if URL has no path contents

    if name.endswith('.[egg.zip](http://egg.zip/)'):
        name = name[:-4] # strip the extra .zip before download

    --> filename = os.path.join(tmpdir, name)
```

Here: https://github.com/pypa/setuptools/blob/main/setuptools/package_index.py#L823

os.path.join() discards the first argument (tmpdir) if the second begins with a slash or drive letter.
name is derived from a URL without sufficient sanitization. While there is some attempt to sanitize by replacing instances of '..' with '.', it is insufficient.

PoC

Attached.

The script downloads a file from a local HTTP server using setuptools' PackageIndex bypassing tmp directory restrictions, and writing to a sensitive location.

\$ python poc.py**Payload file:**

http://localhost:8000/%2fhome%2fuser%2f.ssh%2fauthorized_keys
Written to: /home/user/.ssh/authorized_keys

Risk Assessment

As `easy_install` and `package_index` are deprecated, the exploitation surface is reduced. However, it seems this could be exploited in a similar fashion like [CVE-2022-40897](#), and as described by POC 4 in [CVE-2024-6345](#) report: via malicious URLs present on the pages of a package index.
<https://huntr.com/bounties/d6362117-ad57-4e83-951f-b8141c6e7ca5>

Impact: An attacker would be allowed to write files to arbitrary locations on the filesystem with the permissions of the process running the Python code, which could escalate to RCE depending on the context.



jaraco self-assigned this [on Apr 20, 2025](#)



jaraco added a commit that references this issue [on Apr 20, 2025](#)

Add a check to ensure the name resolves relative to the `tmpdir`. [...](#)



Verified

250a6d1



jaraco closed this as [completed](#) in [250a6d1](#) [on Apr 20, 2025](#)



jaraco changed the title ~~Undisclosed security vulnerability~~ Path traversal in `[PackageIndex.download](http://packageindex.download/)` leads to Arbitrary File Write.
[on Apr 20, 2025](#)



jaraco changed the title ~~Path traversal in `[PackageIndex.download](http://packageindex.download/)` leads to Arbitrary File Write.~~ Path traversal in `PackageIndex.download` leads to Arbitrary File Write. [on Apr 20, 2025](#)



jaraco added [bug](#) [on Apr 20, 2025](#)



cdce8p mentioned this [on Apr 20, 2025](#)

[Update setuptools to 78.1.1 home-assistant/core#143275](#)

WilliamRoyNelson on May 9, 2025



[@jaraco](#) Would it be possible to backport this fix to 75.3.x for Python 3.8 support?

I know Python 3.8 reached End of Life in 2024, but `virtualenv` still supports it:

https://github.com/pypa/virtualenv/blob/2ec4db5d60d9374a0869703c757ead04a7b67c84/src/virtualenv/seed/wheels/embed/_init_.py#L8-L13

It looks like their policy is to support Python versions for 18 months after EOL:

[pypa/virtualenv#2526 \(comment\)](#)

And because setuptools 75.3.2 is bundled with virtualenv, it causes problems with vulnerability scanning tools.

3



 **github-actions** mentioned this in 7 pull requests [on May 26, 2025](#)

-  [Deps: Bump ruff from 0.11.9 to 0.11.10 in the python-packages group greenbone/greenbone-feed-sync#278](#)
-  [ci: run full validation on PRs except release steps, run all steps on `main` sommerfeld-io/container-images#76](#)
-  [Deps: Bump the python-packages group with 2 updates greenbone/greenbone-feed-sync#280](#)
-  [deps\(deps\): update ansible/ansible-lint action to v25.5.0 wayofdev/docker-php-base#151](#)
-  [chore\(master\): release 2.8.20 wayofdev/docker-php-base#152](#)
-  [deps\(deps\): update ansible/ansible-lint action to v25.5.0 wayofdev/docker-php-dev#104](#)
-  [chore\(master\): release 2.8.17 wayofdev/docker-php-dev#105](#)

120 remaining items

Load more



 **muditsinha01** mentioned this in 9 pull requests [last week](#)

-  [Bump versions of multiple dependencies to address vulnerabilities muditsinha01/multi-lang-minimal#34](#)
-  [Bump versions of multiple dependencies to address vulnerabilities muditsinha01/multi-lang-minimal#35](#)
-  [Bump versions of multiple dependencies to address vulnerabilities muditsinha01/multi-lang-minimal#36](#)
-  [Bump versions of multiple dependencies to address vulnerabilities muditsinha01/multi-lang-minimal#37](#)
-  [Bump versions of multiple dependencies to address vulnerabilities muditsinha01/multi-lang-minimal#38](#)
-  [Bump versions of multiple dependencies to address vulnerabilities muditsinha01/multi-lang-minimal#39](#)
-  [Bump versions of multiple dependencies to address vulnerabilities muditsinha01/multi-lang-minimal#40](#)
-  [Bump versions of multiple dependencies to address vulnerabilities muditsinha01/multi-lang-minimal#41](#)
-  [Bump versions of multiple dependencies to address vulnerabilities muditsinha01/multi-lang-minimal#42](#)

jaraco last week

Member

Author



[@jaraco](#) Would it be possible to backport this fix to 75.3.x for Python 3.8 support? I know Python 3.8 reached End of Life in 2024, but virtualenv still supports it:
https://github.com/pypa/virtualenv/blob/2ec4db5d60d9374a0869703c757ead04a7b67c84/src/virtualenv/seed/wheels/embed/_init_.py#L8-L13

It looks like their policy is to support Python versions for 18 months after EOL: [pypa/virtualenv#2526 \(comment\)](#)

And because setuptools 75.3.2 is bundled with virtualenv, it causes problems with vulnerability scanning tools.

I did this for [#5009](#) and 75.3.3 and it has caused quite a bit of confusion and consternation (see [#5142](#)), so I'm reluctant to do it again. Setuptools' policy is to drop support for EOL Pythons shortly after they go EOL. Supporting backports should be reserved for critical issues. These vulnerable code paths are unlikely to be hit, as they are deprecated code paths and the preferred code paths are to install first with pip or Setuptools will invoke pip directly, bypassing this vulnerable code path.

In my opinion, our time is better spent on other issues and not spent managing backports for minimally-impactful fixes just for the sake of satisfying noisy security scans. Please see if you can bypass the alerts. If there is a PR targeting maint/75.3, I'll consider merging it when time permits.

jaraco last week

Member

Author



Oh, and I don't plan on re-opening this issue; this issue was properly closed, but feel free to target a backport PR against this closed issue.



UladzimirTrehubenka mentioned this [last week](#)

[Backport CVE-47273 fix from 78.1.1 to 75.3.3 #5150](#)



muditsinha01 mentioned this in 2 pull requests [last week](#)

[Bump versions of multiple dependencies to address vulnerabilities muditsinha01/multi-lang-minimal#43](#)

[Bump versions of multiple dependencies to address vulnerabilities muditsinha01/multi-lang-minimal#44](#)



muditsinha01 mentioned this [10 hours ago](#)

[Bump versions of multiple dependencies to address vulnerabilities muditsinha01/multi-lang-minimal#45](#)

Sign up for free to join this conversation on GitHub. Already have an account? [Sign in to comment](#)

Assignees



jaraco

Labels

bug

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development

 Code with agent mode

▼

No branches or pull requests

Participants

